

merci-audit:silence-style

La Vida Oculta detrás de las Comunicaciones Seguras con PGP

Art de Côté | Cuadernillo

En el núcleo estático de mercedev.es, se encontró un desafío: cómo permitir a clientes y auditores enviar información confidencial sin comprometer la integridad de la arquitectura estática. Los formularios tradicionales, basados en PHP o Node.js, son complejos y propensos a vulnerabilidades. Además, los correos electrónicos no cifrados pueden ser interceptados por cualquier nodo intermedio.

La solución encontrada fue implementar un modelo de comunicación asimétrica utilizando el estándar PGP (Pretty Good Privacy) mediante la herramienta nativa GnuPG. Esta elección permite generar un par de claves criptográficas locales, protegiendo la clave privada con una frase de paso fuerte.

En lugar de desplegar una API REST para procesar mensajes, se exporta la clave pública a un archivo ASCII de texto plano y se deposita en el directorio `/public/` para que sea servido directamente desde el servidor web como un activo estático. En la página de contacto, se publica el enlace al archivo `.asc` junto con la Huella Digital criptográfica.



En resumen:

En lugar de usar formularios de contacto vulnerables y dependientes de backend, se ha optado por una solución estática y segura: ofrecer una "caja fuerte" pública. Cualquier usuario puede descargar la "llave pública" del proyecto para cifrar un mensaje localmente. Ese mensaje viaja por internet como un bloque de texto inescrutable, y solo el sistema receptor autorizado posee la llave privada para abrirlo.

Para saber más sobre cómo se implementó esta solución, se puede consultar el cuadernillo completo.